

Guía: Ciberseguridad para pymes

Plan práctico de ciberseguridad para empresas de 5 a 50 empleados. Qué hacer primero, en qué invertir y cómo evitar el 90% de los ataques más comunes.

1. El riesgo real (y qué pagan las pymes)

- El 43% de los ciberataques van dirigidos a pymes; la mayoría sobreviven menos de un año tras perder sus datos.
- El vector nº1 es el phishing por email; el nº2, los accesos con contraseñas débiles o reutilizadas.
- Un ransomware medio pide 10.000-50.000€ a una pyme; sin backups, pagar no garantiza nada.
- La ciberseguridad no es opcional: el RGPD obliga a proteger los datos de clientes y empleados.

2. Las 5 medidas que más reducen el riesgo (por orden)

1. 2FA en todo: email, banca online, accesos remotos y paneles de administración.
2. Backups 3-2-1: 3 copias, 2 soportes, 1 fuera de línea, con prueba de restauración.
3. Gestor de contraseñas corporativo: fin de las contraseñas reutilizadas.
4. Actualizaciones automáticas en todos los equipos y software (incluido el antivirus).
5. Firewall con filtrado y red WiFi con WPA3 y red de invitados separada.

3. Phishing: cómo funciona y cómo defenderse

- Regla de oro: nunca se pincha un enlace ni se descarga un adjunto de un correo inesperado.
- Verificar el remitente real: el nombre mostrado puede ser falso, el dominio no.
- Urgencia = sospecha: 'tu cuenta se cerrará en 24h' es la firma del phishing.
- Formación breve a empleados (20 min) al entrar y refresco anual: reduce el riesgo un 60%.
- Sistema de reporte: un botón 'reportar phishing' en el correo corporativo.

4. Accesos y privilegios

- Mínimo privilegio: nadie tiene más permisos de los que necesita para su puesto.
- Cuentas de administrador solo para administradores, nunca para uso diario.
- Baja de empleados: desactivar accesos el mismo día (ver el kit de baja).
- Revisar permisos trimestralmente: empleados que cambian de rol arrastran accesos viejos.

5. Presupuesto orientativo (pymes)

Medida	Coste típico	Riesgo que cubre
2FA + gestor de contraseñas	5-15€/usuario/año	Robo de credenciales
Backups 3-2-1 con nube	30-80€/mes	Ransomware, borrados
Firewall de nueva generación	300-900€ una vez	Exposición externa
Formación anti-phishing	5-10€/usuario/año	Ingeniería social

Auditoría anual de seguridad	300-800€	Fugas de configuración
------------------------------	----------	------------------------

6. Plan de acción 30 días

- Semana 1: activar 2FA en todas las cuentas críticas y el gestor de contraseñas.
- Semana 2: configurar backups 3-2-1 y probar una restauración real.
- Semana 3: actualizar todos los equipos, router y firewalls; desactivar accesos obsoletos.
- Semana 4: formación anti-phishing a todo el equipo y documentar el plan de incidentes.